

# YKP HR V1 — Panduan Akun Divisi & Ganti Password

Provisioning akun oleh HR · Password sementara + paksa ganti · Akun trial per divisi

**Ringkasan:** HR kini dapat membuat akun untuk setiap divisi. Setiap akun baru dibuat dengan *password sementara* dan *wajib diganti sendiri oleh user* saat login pertama — sehingga HR tidak pernah mengetahui password final milik user.

## 1. Akun Trial per Divisi

Untuk keperluan trial/pilot, tersedia satu akun untuk setiap divisi. Semua akun dibuat dengan `must_change_password = true` — user wajib mengganti password saat login pertama.

| Divisi         | Username   | Password Sementara | Role           |
|----------------|------------|--------------------|----------------|
| Owner          | owner      | owner123           | owner          |
| Super Admin    | superadmin | superadmin123      | super_admin    |
| HR Admin       | hradmin    | hradmin123         | hr_admin       |
| Finance        | finance    | finance123         | finance_admin  |
| Brand Manager  | brandmgr   | brandmgr123        | brand_manager  |
| Outlet Manager | outletmgr  | outletmgr123       | outlet_manager |
| Supervisor     | supervisor | supervisor123      | supervisor     |
| Employee       | employee   | employee123        | employee       |
| Viewer         | viewer     | viewer123          | viewer         |

**Penting:** Password di atas adalah *password sementara*. Setiap user **wajib mengganti password sendiri** pada login pertama. Jangan gunakan password sementara untuk produksi.

## 2. Cara Membuat Akun Trial

Jalankan perintah berikut dari folder `ykp-hr-v1` :

```
# 1. Pastikan kolom must_change_password ada (idempotent)
npm run sheets:bootstrap

# 2. Buat akun trial (skip username yang sudah ada)
npm run sheets:seed-trial
```

Script membaca brand/outlet dari spreadsheet, membuat satu akun per role, dan menyimpan password sebagai hash bcrypt. Script aman dijalankan berulang — username yang sudah ada akan dilewati.

**Mode demo (tanpa Google Sheets):** akun trial juga tersedia di mock store. Jalankan `USE MOCK_DB=true`  
`npm run dev` untuk mencoba tanpa kredensial Google.

### 3. Alur Login & Paksa Ganti Password

Berikut alur yang terjadi saat user login dengan password sementara:

1. User login dengan **username + password sementara**.
2. Sistem mengenali flag `must_change_password = true`.
3. User **diarahkan otomatis** ke halaman `/change-password`.
4. User memasukkan **password lama + password baru + konfirmasi**.
5. Password baru disimpan sebagai hash bcrypt, flag di-clear, session diperbarui.
6. User diarahkan ke dashboard `/hr`.

**Hasil:** HR tidak pernah mengetahui password final. Jika HR perlu mereset password user, user kembali dipaksa mengganti password pada login berikutnya.

#### Persyaratan Password Baru

- Minimal **6 karakter**.
- Harus **berbeda** dari password lama.
- Konfirmasi harus **cocok** dengan password baru.

### 4. HR Membuat Akun Divisi

HR kini memiliki akses `view / create / update` pada resource `user`. HR dapat membuat akun divisi dari menu **User & Role**.

#### Langkah membuat akun

1. Login sebagai **HR Admin** (atau owner/super\_admin).
2. Buka menu **User & Role** di sidebar.
3. Klik **+ Tambah User**.
4. Isi **Username**, **Password sementara**, **Role**, dan scope **Brand / Outlet**.
5. Klik **Simpan**.

**Scope:** Brand Manager hanya melihat brand-nya sendiri; Outlet Manager / Supervisor hanya melihat outlet-nya; Employee hanya melihat data dirinya sendiri. Scope diatur otomatis dari role + brand/outlet yang dipilih.

#### Reset password oleh HR

HR dapat mereset password user melalui API `PUT /api/hr/users` dengan field `password`. Setiap reset otomatis menetapkan `must_change_password = true`, sehingga user wajib mengganti password pada login berikutnya.

## 5. Batasan Keamanan (RBAC)

| Resource      | HR Admin | Super Admin | Owner |
|---------------|----------|-------------|-------|
| user — view   | ✓        | ✓           | ✓     |
| user — create | ✓        | ✓           | —     |
| user — update | ✓        | ✓           | —     |
| user — delete | —        | —           | —     |

**Role elevated:** Hanya `owner` / `super_admin` yang dapat membuat atau menetapkan role `owner` / `super_admin`. HR tidak dapat menaikkan role ke level tersebut.

## 6. Endpoint API

| Method | Endpoint                               | Deskripsi                                               |
|--------|----------------------------------------|---------------------------------------------------------|
| POST   | <code>/api/auth/login</code>           | Login; mengembalikan <code>mustChangePassword</code>    |
| POST   | <code>/api/auth/change-password</code> | Ganti password (verifikasi lama, hash baru, clear flag) |
| GET    | <code>/api/hr/users</code>             | Daftar user (tanpa hash password)                       |
| POST   | <code>/api/hr/users</code>             | Buat user (set <code>must_change_password=true</code> ) |
| PUT    | <code>/api/hr/users</code>             | Update role/status/scope/password                       |

## 7. Checklist Sebelum Pilot

- Jalankan `npm run sheets:bootstrap` untuk menambahkan kolom `must_change_password`.
- Jalankan `npm run sheets:seed-trial` untuk membuat akun divisi.
- Bagikan username + password sementara ke masing-masing divisi.
- Pastikan setiap user mengganti password pada login pertama.
- Ubah password default `owner` / `hradmin` sebelum produksi.